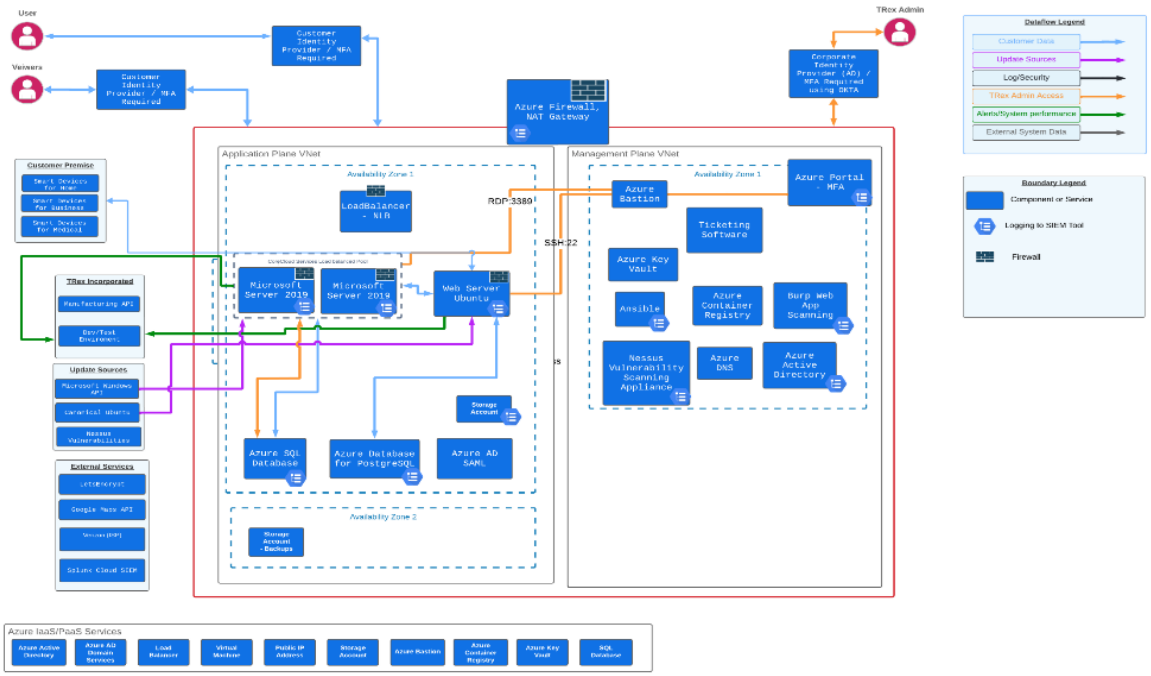
TRex SE

Application Info

TRex, Inc. develops smart devices to be used for homes and businesses and in the medical industry. These smart devices include alarm systems, appliances, and human-worn devices. They also collect personal identifiable information (PII), protected health information (PHI), credit card information, device and security information, and other sensitive data. The devices can be configured to be linked to first responders, family members, or any authorized users that a business and/or the owner of the device chooses

Architecture

Architecture Diagram



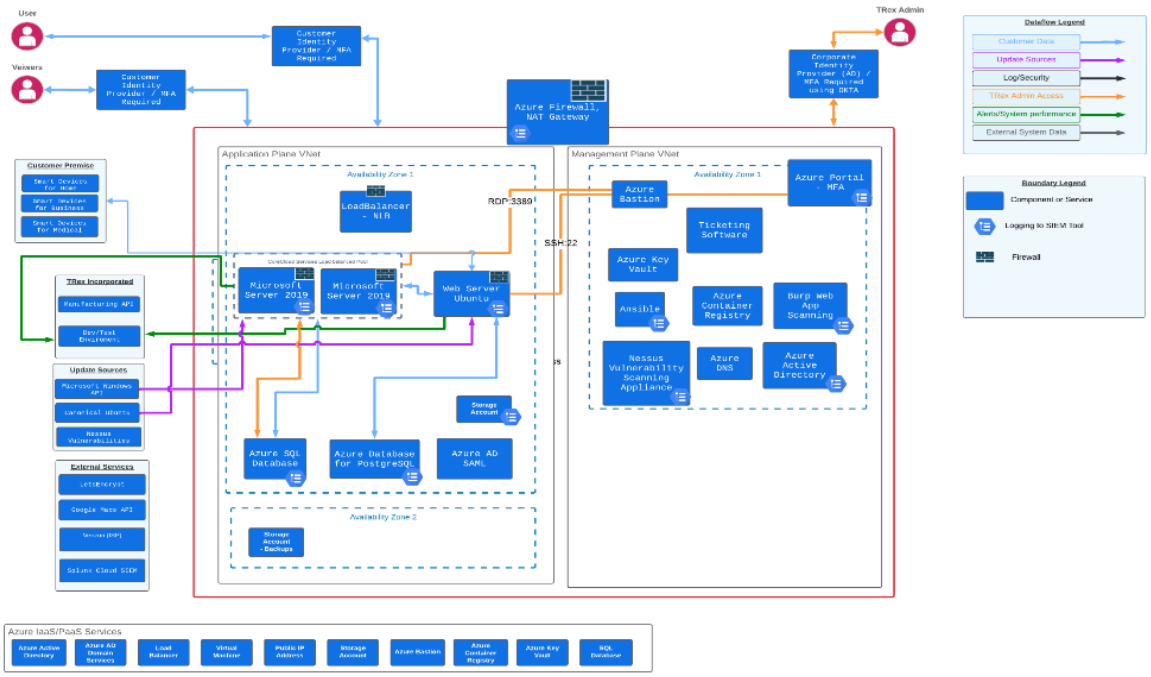
Dataflow

Introduction

There are several dataflows within the TRex SE environment including customer data, update sources, logging/security, TRex administration, alerts, and external system data. The two main dataflows are the customer to devices, devices to TRex SE, and management plane to application plane. Customers interact with their devices through an ISP provider. Although customers can access some offline functionality, there must be an active and stable internet connection for the device to be able to pull and push accurate and current information from TRex SE. Smart devices respond to customer voices, fingerprints, and in the case of medical devices, physical attributes such as heart rate, blood sugar levels, blood pressure, etc. This information, once collected from the customer, is communicated to

TRex SE through an encrypted tunnel using FIPS 140-2 validated encryption. TRex SE analyzes the data sent from the device to either warn the user about potentially harmful activities or statistics, or if a certain range will prompt the user to dial 911 immediately, and for some medical devices, the device will use E911 and dial for the customer. For home and business devices, TRex SE may make recommendations based on the customer's use of the device as well as send health statistics of the device itself. For medical devices, TRex SE performs trend analysis to properly baseline the health of the individual using the device. This information is communicated to the user of the device but can also be communicated to authorized users, known as Viewers, of the information that the device produces. TRex admins are responsible for managing the TRex SE application. They perform several security and continuous monitoring activities.

Dataflow Diagram



Assumptions

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
A-0024	The Azure Active Directory and SAML configurations enforce strict identity and access controls for all users			
A-0023	All storage accounts and Azure SQL Databases encrypt data both at rest and in transit by default			
A-0022	The system assumes that the single-user workflow for the HR specialist			

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
	remains fully contained and trusted			
A-0021	No packet sniffing or eavesdropping is possible on the internal wireless network due to built-in protections			
A-0020	The HR specialist treats printing the updated spreadsheet as a high-security task equivalent to emailing sensitive data			
A-0019	Nessus vulnerability scanning is performed regularly and all critical findings are immediately remediated			
A-0018	The Azure Bastion and RDP/SSH access points are the only secure methods for administrative access			
A-0017	External services, Encrypt, Google Maps API, Verizon ISP, Splunk only transmit data over encrypted channels			
A-0016	Update sources (Microsoft Windows API, Canonical Ubuntu, Nessus) are always secure and not compromised			
A-0015	Smart devices for home, business, and medical are fully trusted and cannot introduce risks to the network			
A-0014	All Azure resources in the Application Plane VNet and Management Plane VNet are properly segmented and isolated			
A-0013	The load balancer and web servers only accept			

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
	secure, encrypted connections from internal clients			
A-0012	MFA is enforced for all access to the HR spreadsheet and related systems			
A-0011	The system assumes that convenience features like automatic wireless printing do not introduce security risks.			
A-0010	The Azure Firewall and NAT Gateway fully protect all internal wireless transmissions			
A-0009	Data transmitted to the printer is never sent in plaintext or with weak encryption			
A-0008	The HR specialist always verifies the security settings before printing sensitive employee data			
A-0007	No unauthorized devices can be within radio range of the wireless network without detection			
A-0006	The corporate Wi-Fi network is not shared with guests, visitors, or untrusted devices			
A-0005	Users receive regular security awareness training that specifically addresses risks of wireless printing			
A-0004	The system requires secure print release or user authentication at the printer before releasing sensitive HR documents			

Assumption Number	Assumption	Linked Threats	Linked Mitigations	Comments
A-0003	The printer is isolated on a dedicated VLAN or separate network segment from other devices			
A-0002	All print jobs transmitted over the wireless network are automatically encrypted end-to-end.			
A-0001	The wireless network connection between the HR specialist's laptop and the printer uses strong encryption such as WPA3 by default			The wireless network connection between the HR specialist's laptop and the printer uses strong encryption such as WPA3 by default

Threats

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
T-0004	An external threat actor Both WPA2 downgrade attacks and KRACK require the attacker to be within radio range of the Wi-Fi network can perform reconnaissance and intrusion activities against the exposed attack surface, which leads to the application behaving in unintended ways, resulting in reduced availability of registration	M-0002: Disable WPA2 entirely and enforce WPA3-Personal or WPA3-Enterprise only no transition mode.		Identified			

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	status						
T-0003	A threat actor the wireless network supports or falls back to WPA2 can perform reconnaissance and intrusion activities against the exposed attack surface, which leads to unnecessary and excessive costs, resulting in reduced availability of billing			Identified			
T-0002	An external threat actor Both WPA2 downgrade attacks and KRACK require the attacker to be within radio range of the Wi-Fi network can access sensitive data, which leads to the application behaving in unintended ways, resulting in reduced confidentiality of registration status			Identified			
T-0001	A threat actor the wireless network supports or falls back to WPA2 can perform			Identified			

Threat Number	Threat	Mitigations	Assumptions	Status	Priority	STRIDE	Comments
	reconnaissance and intrusion activities against the exposed attack surface, which leads to the actor being able to do anything the user can do, resulting in reduced confidentiality of billing						

Mitigations

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
M-0013	Disable weak TLS versions and ciphers in Azure configurations			Identified	
M-0012	Enforce Azure AD Conditional Access with MFA for all HR system access			Identified	
M-0011	Disable direct wireless printing; require jobs to go through a secure central print server			Identified	
M-0010	Route all print traffic through a TLS encrypted print server			Identified	
M-0009	Use print policies that block printing sensitive documents to			Identified	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
	unsecured printers				
M-0008	Reduce Wi-Fi signal strength and coverage to the minimum required inside the buildin			Identified	
M-0007	Implement a separate guest Wi-Fi network with full isolation no access to internal resources			Identified	
M-0006	Conduct mandatory annual or quarterly training focused on wireless and printer risks			Identified	
M-0005	Enable job auto-purge after a short timeout if not released			Identified	
M-0004	Place the printer on a dedicated VLAN with strict Network Security Group (NSG) rules in Azure			Identified	
M-0003	Enable IPP over TLS (IPPS) or use encrypted printing protocols			Identified	
M-0002	Disable WPA2 entirely and	T-0004: An external threat		Identified	

Mitigation Number	Mitigation	Threats Mitigating	Assumptions	Status	Comments
	enforce WPA3-Personal or WPA3-Enterprise only no transition mode.	actor Both WPA2 downgrade attacks and KRACK require the attacker to be within radio range of the Wi-Fi network can perform reconnaissance and intrusion activities against the exposed attack surface, which leads to the application behaving in unintended ways, resulting in reduced availability of registration status			
M-0001	Enforce 802.1X certificate-based authentication no PSK for corporate Wi-Fi			Identified	

Impacted Assets

Assets Number	Asset	Related Threats
AS-0001	registration status	T-0004: An external threat actor Both WPA2 downgrade attacks and KRACK require the attacker to be within radio range of the Wi-Fi network can perform reconnaissance and intrusion activities against the exposed attack surface, which leads to the application behaving in unintended ways, resulting in reduced availability of registration status T-0002: An external threat actor Both WPA2 downgrade attacks and KRACK require the attacker to be within radio range of the Wi-Fi network can access sensitive data, which leads to the application behaving in unintended ways, resulting in reduced confidentiality of registration status
AS-0002	billing	T-0003: A threat actor the wireless network supports or falls back to WPA2 can perform reconnaissance and intrusion activities against the exposed attack surface, which leads to unnecessary and

Assets Number	Asset	Related Threats
		excessive costs, resulting in reduced availability of billing **T-0001**: A threat actor the wireless network supports or falls back to WPA2 can perform reconnaissance and intrusion activities against the exposed attack surface, which leads to the actor being able to do anything the user can do, resulting in reduced confidentiality of billing